

DEVOPS

CI/CD

Sesión 0

AUTOMATIZANDO EL CICLO DE VIDA DEL SOFTWARE

DevOps





Buscar

Empleos ▾ | Fecha de publicación ▾ | Nivel de experiencia ▾

DevOps en España

2.700 resultados

Crear alerta ☐

Obtén más información sobre estos cambios que se aplicarán a tu uso continuado de





Buscar

Empleos ▾ | Fecha de publicación ▾ | Nivel de experiencia ▾

php en España

2.654 resultados

Crear alerta ☐

IT / Sysadmin en las empresas

- **Hardware:**

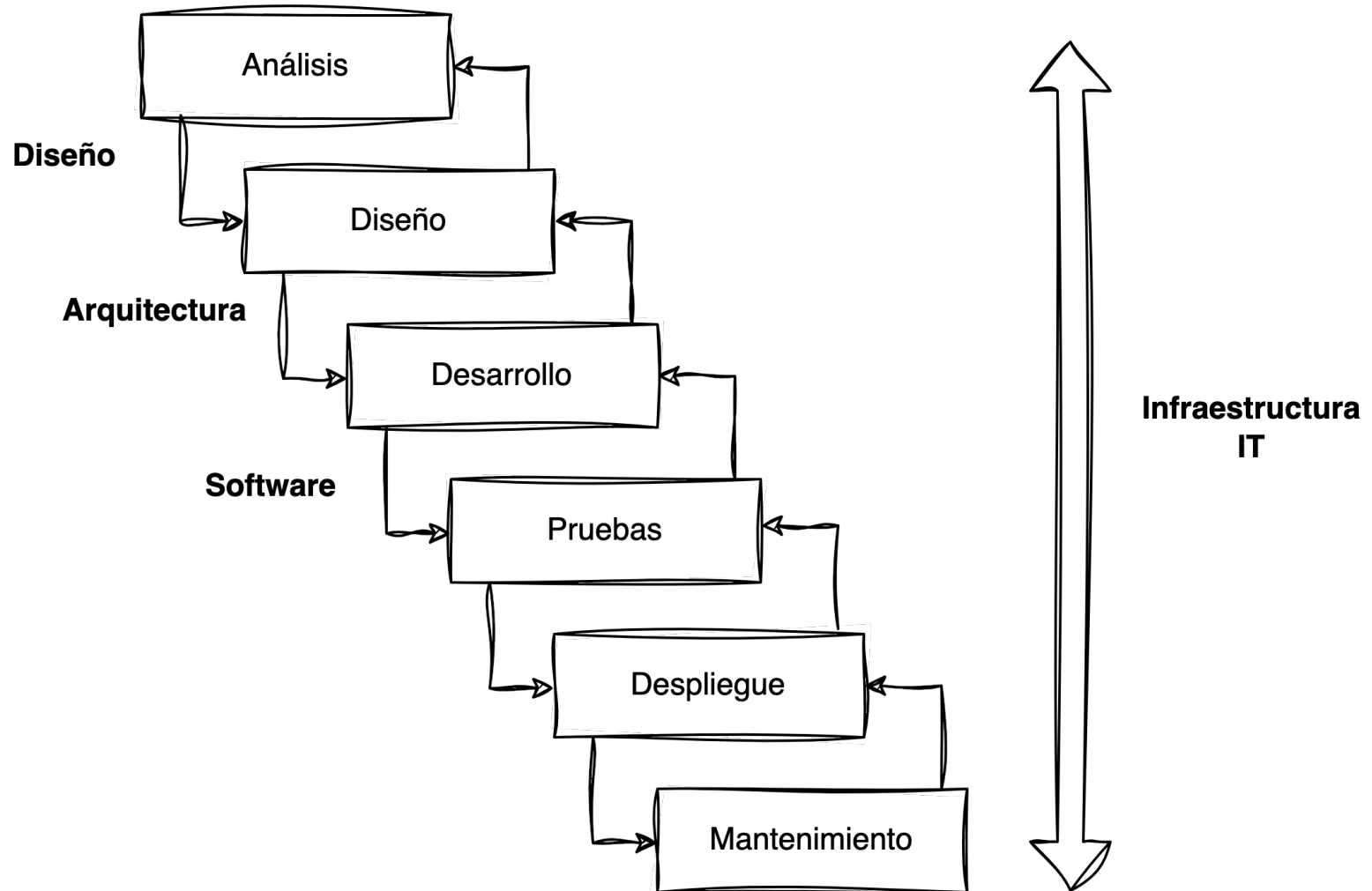
- Infraestructura (local y remota, implantaciones, etc).
- Soporte técnico.
- Gestión de activos.
- Seguridad física.
- ...

- **Software:**

- Plataformar equipos.
- Instalación y configuración de bases de datos.
- Implantación de gestores documentales, configuración NAS, SMB...
- Licencias, actualizaciones de sistemas operativos, inventariado de software.
- Seguridad lógica (Active Directory, SSO, VPN...)
- En medianas/grandes empresas con **desarrollos de aplicaciones propias o para/en cliente**, soporte vertical al ciclo de vida de desarrollo (cloud + on-prem).
- ...

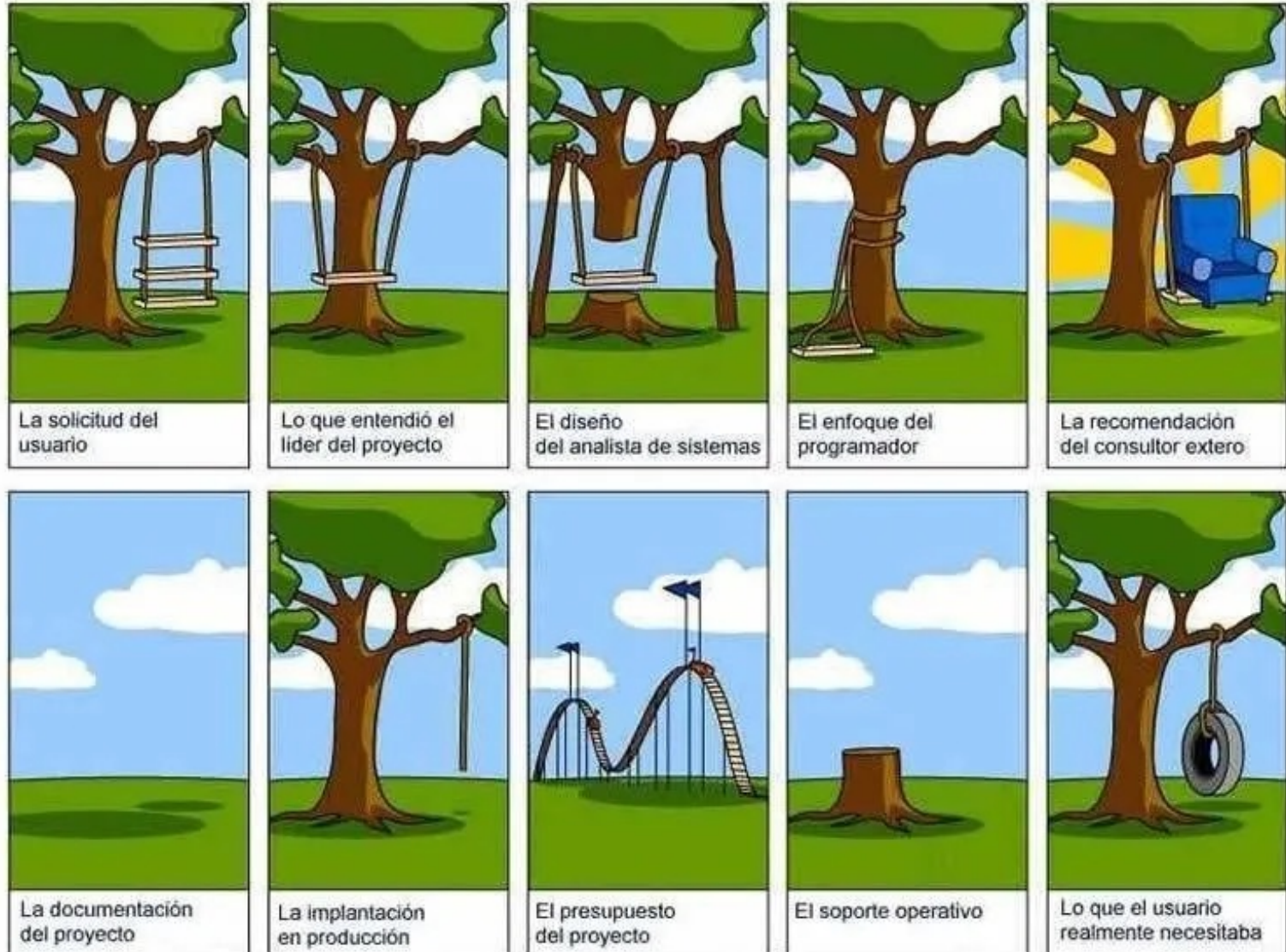
Ciclos de vida del software

Metodología Cascada



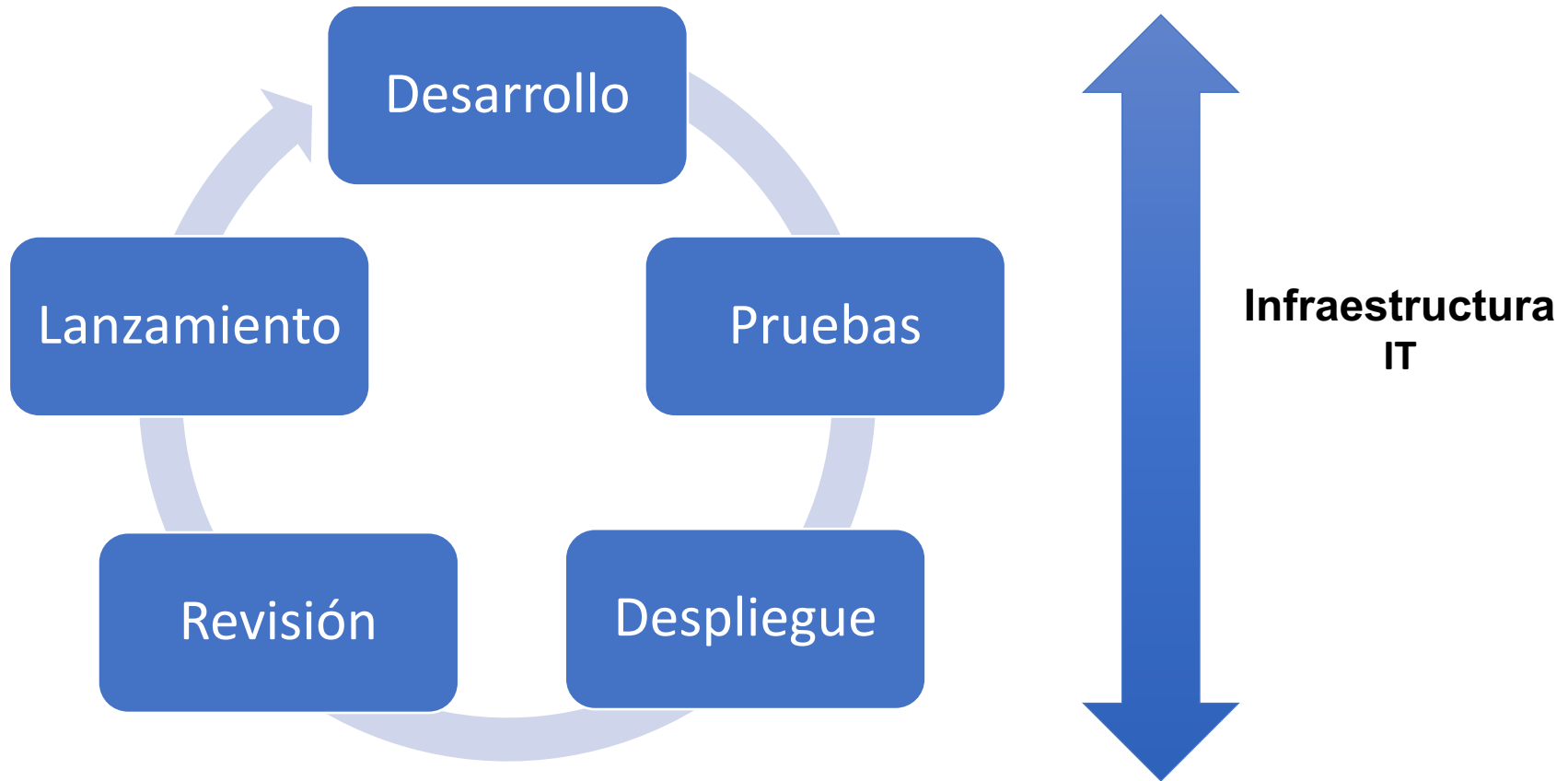
Ciclos de vida del software

Metodología Cascada



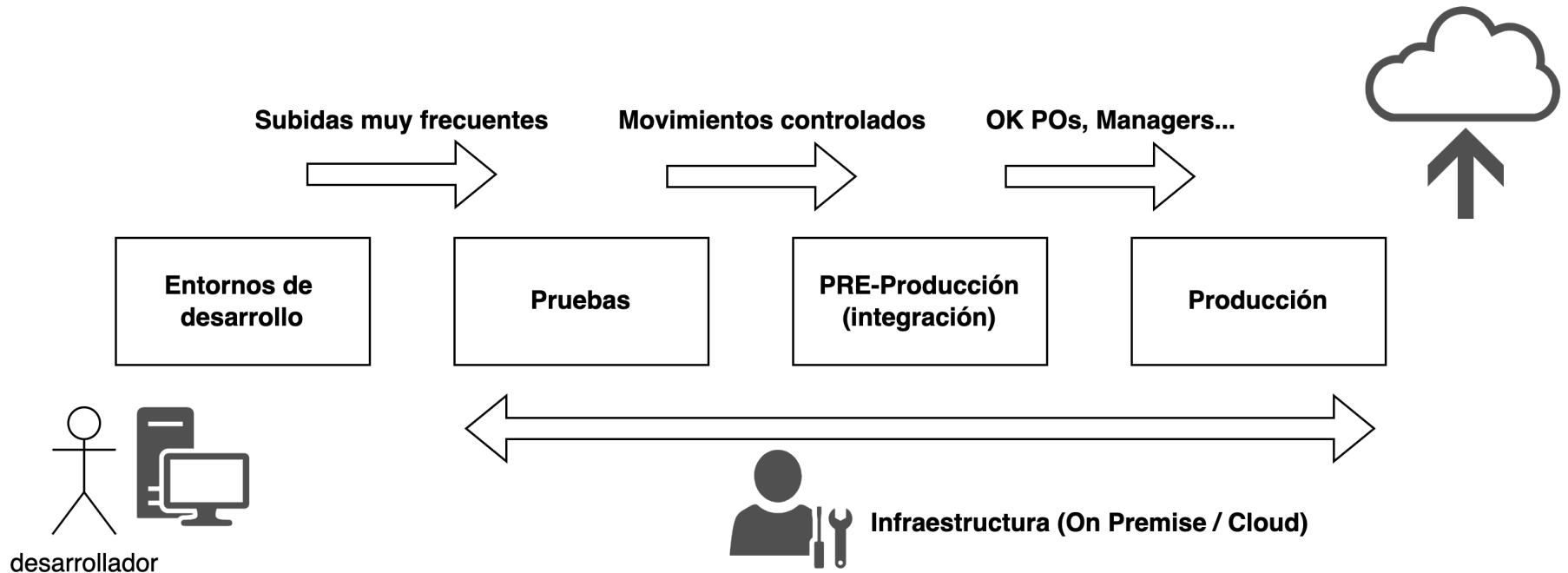
Ciclos de vida del software

Metodologías Agile



Sprints en semanas -> entregas rápidas, feedback de cliente / PO (product owner)

Ejemplo: Flujo de implantación de software

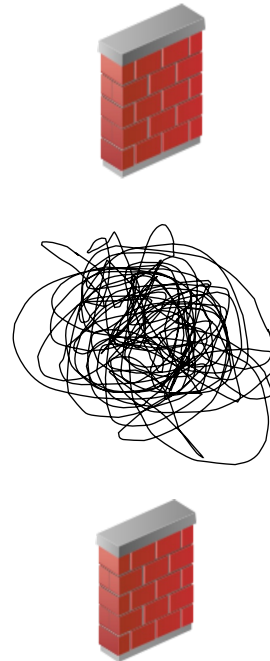


Enfoque tradicional (aún vigente)



Desarrolladores

- Vistos por IT como demasiado aventurados. Amenaza a la estabilidad.
- Bugs que comprometen el sistema.
- Buscan mejorar el producto, muchas veces sin pensar en la infraestructura.



IT (operaciones):

- Vistos por los desarrolladores como Inflexibles al cambio y obstáculo al desarrollo.
- Buscan la estabilidad y seguridad de la infraestructura.



Enfoque tradicional (aún vigente)

- Equipos desconectados.
- Puesta en producción de las soluciones más ineficiente y ciclos lentos.
- Posibilidad de **errores humanos** en configuración de despliegues en entornos previos y productivos.
- Si algo sale mal o surge algún problema, reproches mutuos.
- ROI bajo para la empresa.
- Trabajadores descontentos y desmotivados.
- Se pone en riesgo continuidad de productos.

¿SOLUCIÓN? ¿IDEAS?

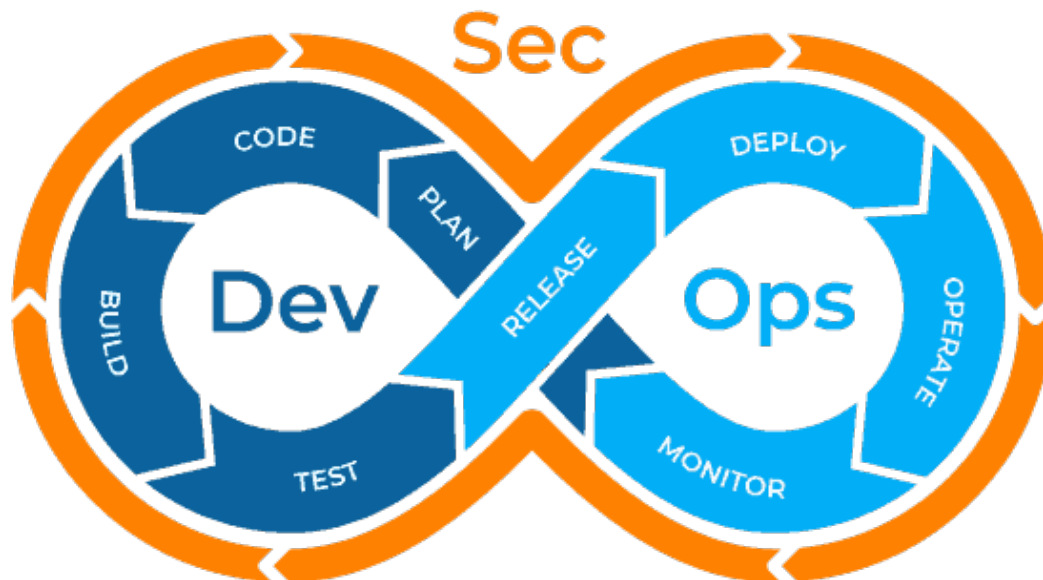
DEVOPS!



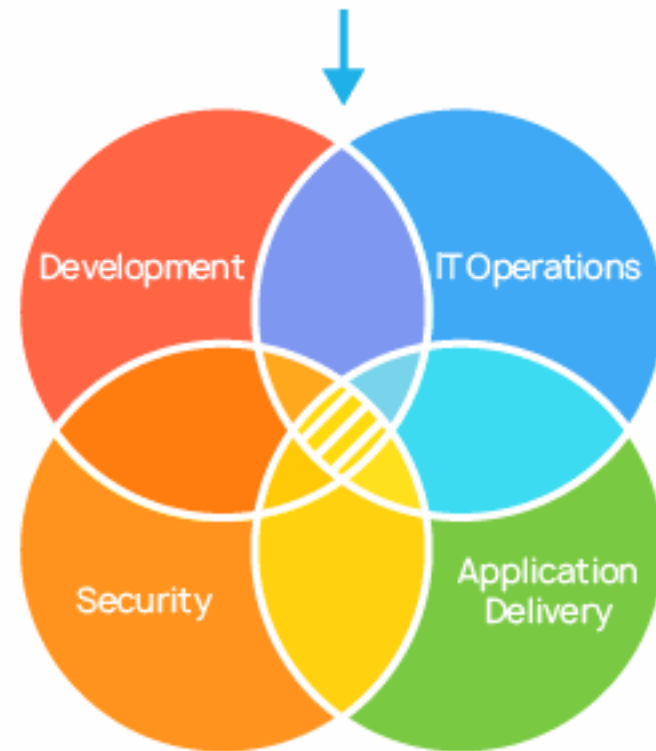
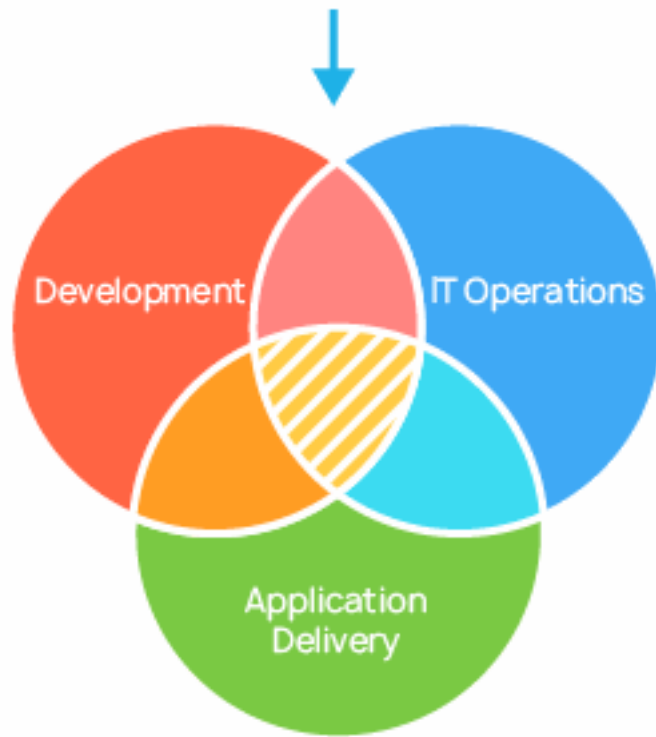
Filosofía devops

- Busca entrega más rápida, garantizando la calidad y seguridad de una entrega.
- A través de colaboración entre las diferentes áreas implicadas:
 - IT
 - Seguridad
 - Calidad (QA)
 - Desarrollo
- Habilitando, en la medida de lo posible, la automatización y definición de procesos del ciclo de vida.

DEVOPS -> DEVSECOPS



DevOps **VS** DevSecOps



CI / CD

- **Integración Continua (CI):** Integración frecuente de código, verificada automáticamente.
- **Entrega Continua (CD):** Despliegue automático frecuente en producción.

¿ DEVOPS == CI/CD ?

CI / CD

Ciclo de Vida

- **CI: Integración continua:**

- Los desarrolladores realizan subidas frecuentes.
- Test automáticos unitarios y de integración.
- Integración con repositorio de código.
- Análisis estático de código en busca de bugs, problemas de seguridad (i.e., XEE injection), etc.
- Detección de fuga de secretos (contraseñas en código).
- Detección de amenazas de seguridad / dependencias / vulnerabilidades.

- **CD: Entrega continua:**

- Pruebas adicionales previo despliegue en entornos previos.
- Automatización de despliegue (pruebas, preproducción, producción).
- Posibilidad de integrar PAAS (dimensionado de contenedores con kubernetes, Openshift, Azure).
- Políticas de aprobación y verificación.
- Uso de pipelines automatizadas (Jenkins, GitLabCI, Github Actions).
- Implementar/configurar estrategias modernas de despliegue (Canary, Blue-Green, A/B testing).

CI/CD pipeline



Fuente: redhat

Etapa CI – Automatizar:

- Verificar compilación
- Calidad del código (QA)
- Análisis estático de código (QA+Sec)
- Detección temprana de fuga de datos (Sec)
- Detección temprana de amenazas de seguridad (Sec) – **shift left**
- **Cualquier otra política definida por la compañía**

Etapa CD – Automatizar:

- Generación de versiones.
- Despliegue de releases a repositorios intermedios (des, pre, int, etc).
- Despliegue a producción (pro).
- Implementación de políticas de revisión y autorización.
- Posibilidad de implementar PAAS (kubernetes, Openshift, Azure).

Desafíos y mejores prácticas

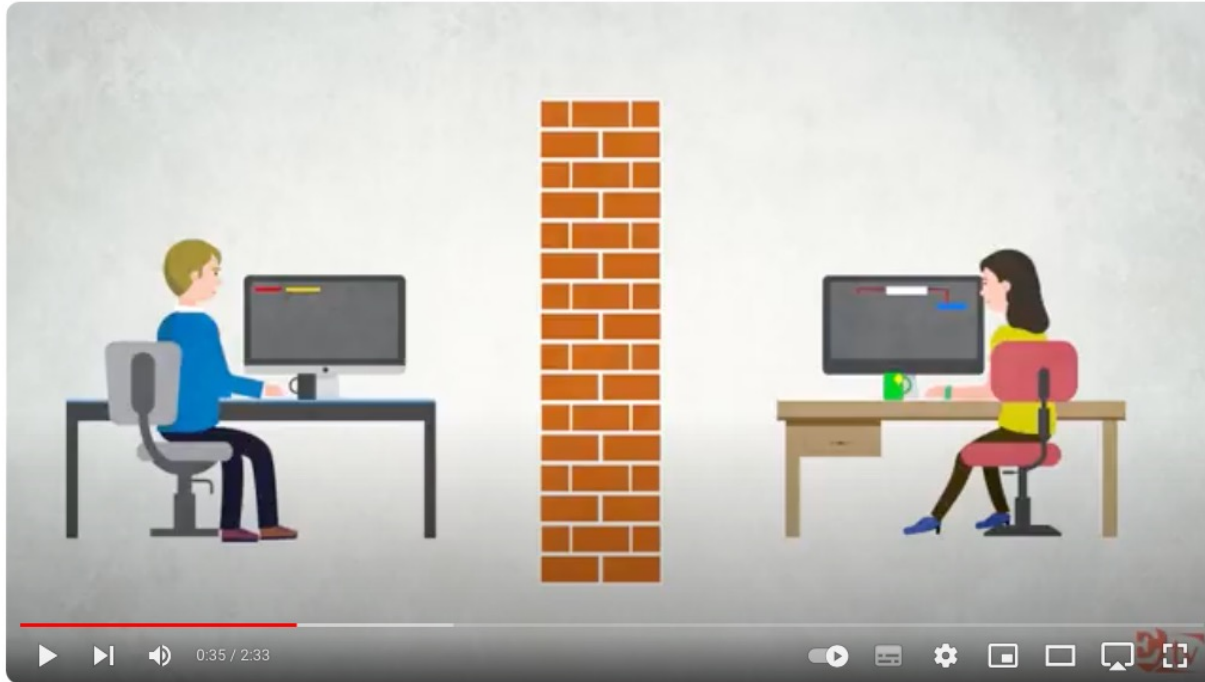
- **Desafíos**

- **Resistencia** cultural: Algunos equipos prefieren seguir utilizando técnicas tradicionales.
- Automatización no siempre sencilla.
- Multitud de herramientas, elección.
- Políticas de seguridad en CI -> **complejidad** en función de tamaño empresa, software existente.

- **Mejores prácticas:**

- Automatizar comenzado por el inicio (CI) -> Pruebas, despliegues en desarrollo, monitorización.
- Establecer una cultura de colaboración entre los equipos (reuniones informativas, comunicados, publicidad de las políticas, acuerdos para implementar EOLs).
- Adopción gradual hasta llegar a producción.
- Incluir seguridad en los procesos de CI y CD (DevSecOps).

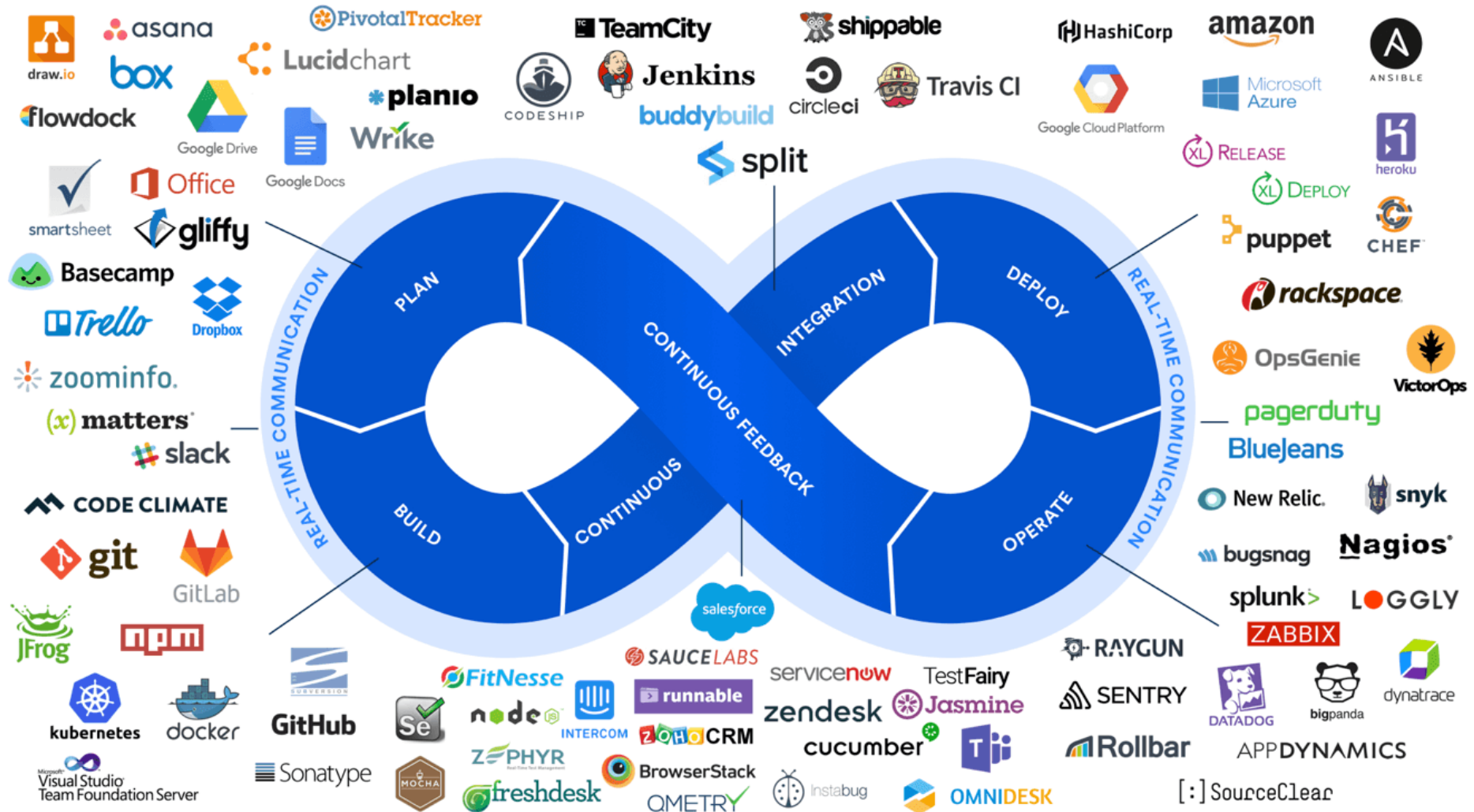
Desafíos y mejores prácticas



<https://www.youtube.com/watch?v=p-bOnV8FRMQ>

Y todo esto, ¿Cómo?

Comunicación + Software: Herramientas On-Premise y/o Cloud para cada paso del flujo (pipeline).





Software destacado On-prem / Cloud

Análisis estático de código y Seguridad (CI)

4 projects		Perspective: Overall Status	Sort by: Name		
★ app	Passed	Last analysis: 21 minutes ago			
Bugs	Vulnerabilities	Hotspots Reviewed	Code Smells	Coverage	Duplications
0 A	0 A	0.0% E	0 A	0.0%	0.0%
531 XS		XML, Kotlin			
☆ app	Passed	Last analysis: 14 days ago			
Bugs	Vulnerabilities	Hotspots Reviewed	Code Smells	Coverage	Duplications
0 A	0 A	0.0% E	0 A	0.0%	0.0%
531 XS		XML, Kotlin			
★ Sonar	Passed	Last analysis: 4 minutes ago			
Bugs	Vulnerabilities	Hotspots Reviewed	Code Smells	Coverage	Duplications
0 A	0 A	- A	0 A	96.1%	0.0%
159 XS		XML, Swift			

Versión community gratuita. <https://www.sonarsource.com>



Software destacado On-prem / Cloud

Seguridad (CI)

Snyk Internal (Org) > Projects > Project

☐ Vulnerabilities4

☐ License issues0

SEVERITY

☐ Critical2

☐ High1

☐ Medium1

☐ Low0

PRIORITY SCORE

Scored between 0 - 1000

FIXABILITY

☐ Fixable4

☐ Partially fixable0

☐ No fix available0

EXPLOIT MATURITY

☐ Mature1

☐ Proof of concept3

☐ No known exploit0

☐ No data0

STATUS

☒ Open4

☐ Patched0

☐ Ignored0

C

org.apache.logging.log4j:log4j-core - Remote Code Execution (RCE)

VULNERABILITY | CWE-94 | CVE-2021-44228 | CVSS 10 | CRITICAL | SNYK-JAVA-ORGAPACHELOGGINGLOG4J-2314720

Insights: We strongly recommend fixing this vulnerability. If it cannot be fixed by upgrading to the latest version, remove `JndiLookup.class` from the class path by running:
`zip -q -d log4j-core-*.jar org/apache/logging/log4j/core/lookup/JndiLookup.class`
For additional mitigation advice, please see our [Log4Shell remediation cheat sheet](#).

Introduced throughorg.apache.logging.log4j:log4j-core@2.14.1

Fixed inorg.apache.logging.log4j:log4j-core@2.3.1, @2.12.2, @2.15.0

Exploit maturityMATURE

Social trendsTRENDINGView tweets

Show more detail

NEW

Learn about this type of vulnerability

Ignore

Fix this vulnerability

H

org.apache.logging.log4j:log4j-core - Denial of Service (DoS)

VULNERABILITY | CWE-400 | CVE-2021-45105 | CVSS 7.5 | HIGH | SNYK-JAVA-ORGAPACHELOGGINGLOG4J-2321524

Introduced throughorg.apache.logging.log4j:log4j-core@2.14.1

Fixed inorg.apache.logging.log4j:log4j-core@2.3.1, @2.12.3, @2.17.0

Exploit maturityPROOF OF CONCEPT

Show more detail

NEW

Learn about this type of vulnerability

Ignore

Fix this vulnerability

C

929

Vulnerability

Remote Code Execution (RCE)

CVE-2021-44228

CWE-94

demo-clinton/deployment.apps/snyk-juice-sh

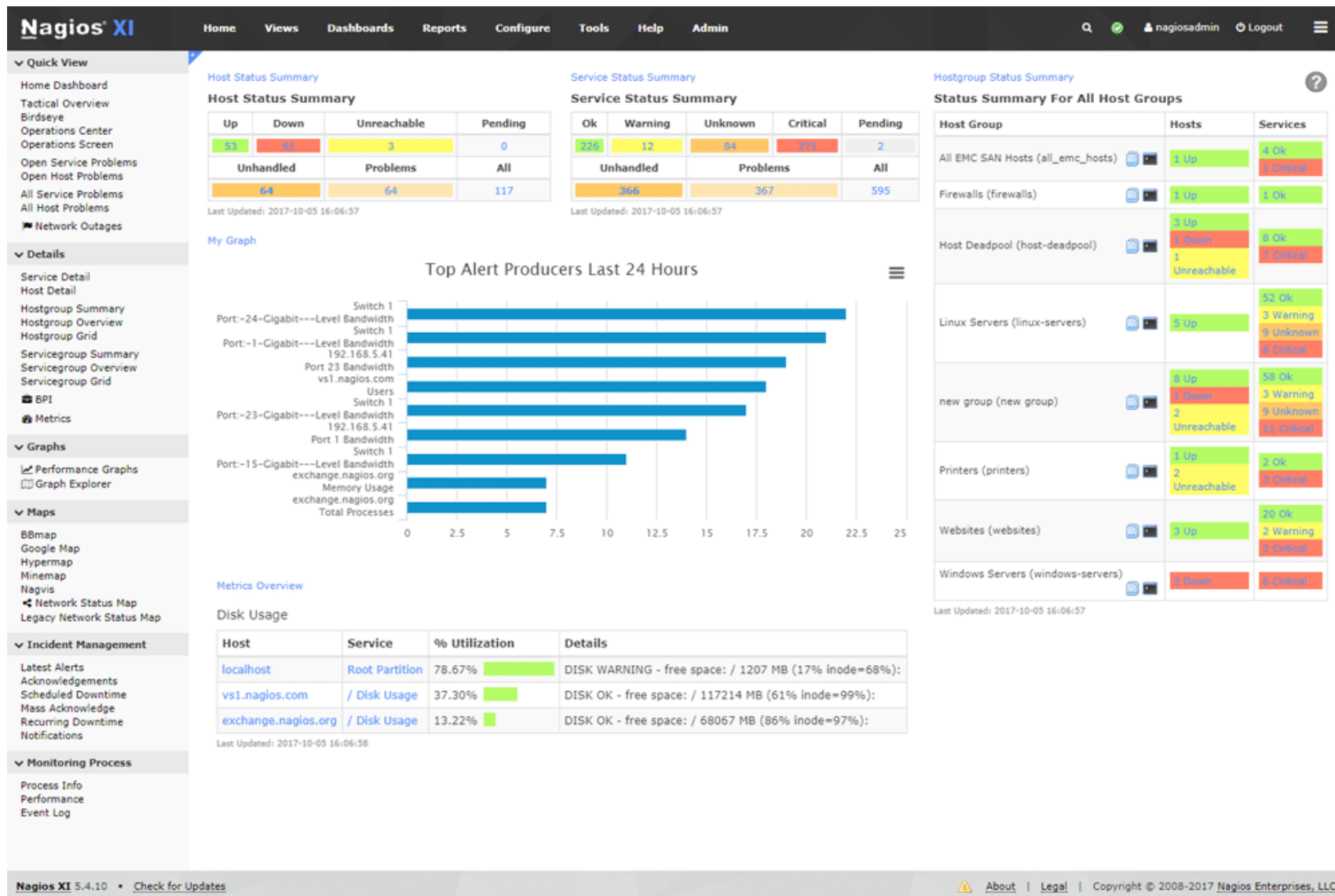
Mature

Upgrade

Mar 17, 2022

Snyk Open Source

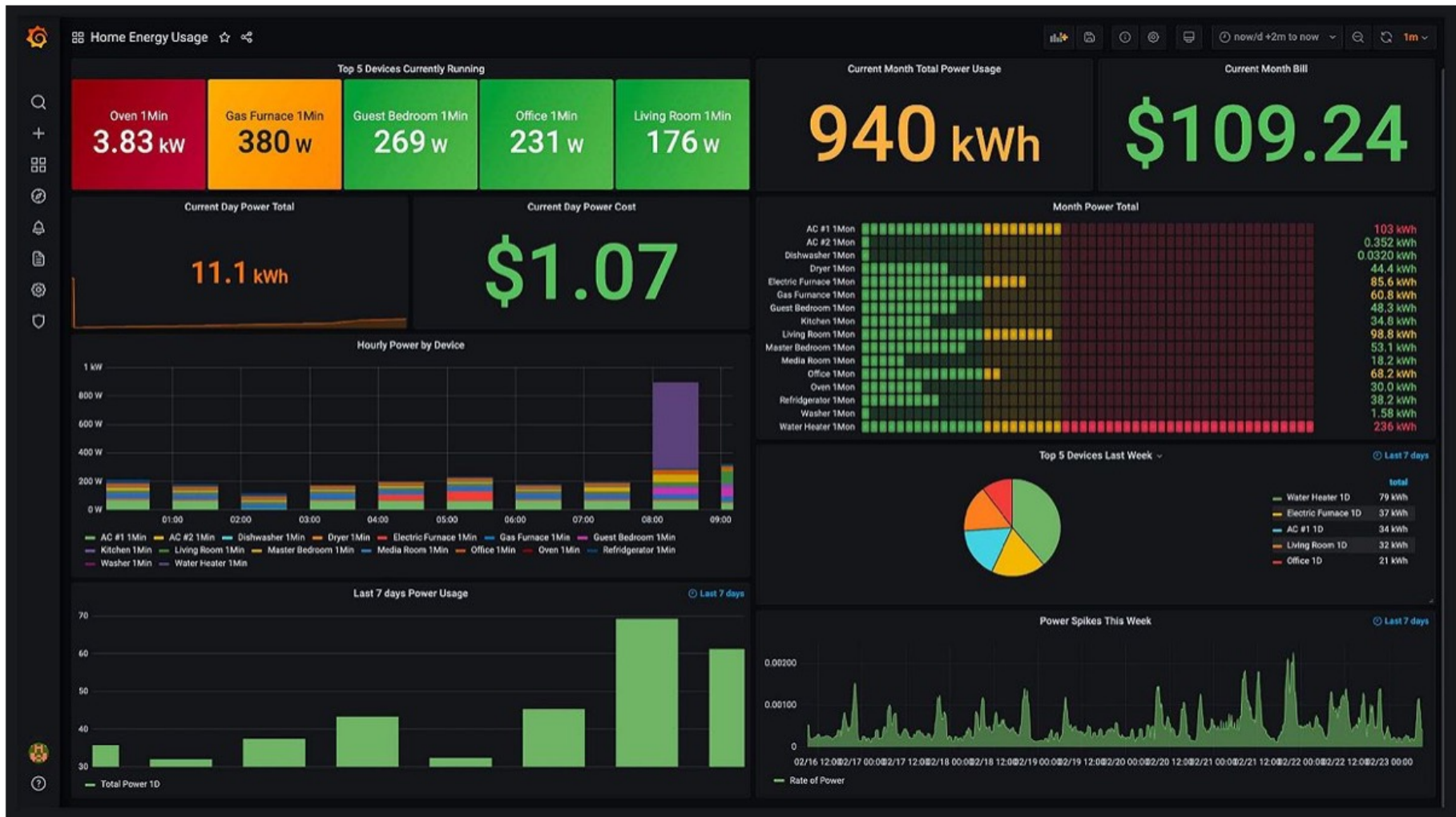
op:/usr/share/java



Software destacado On-prem / Cloud Monitorización (CI / CD)



Dashboard anything. Observe everything.





Software destacado On-prem / Cloud

Orquestación y despliegue (CI / CD)

**Jenkins**

search [?](#) [log in](#)

[ENABLE AUTO REFRESH](#)

People

Build History

Project Relationship

Check File Fingerprint

Disk usage

We Need Beer

Build Queue

No builds in the queue.

Build Executor Status

master

1 Idle

2 Idle

celery

1 Idle

2 Idle

remote-slave-3

(offline)

remote-slave-6

1 Idle

2 Idle

remote-slave-7

(offline)

remote-slave-8

(offline)

AllAll DisabledAll FailedAll UnstableInfrastructureJenkins coreLibrariesOther Projects

S	W	Name ↓	Last Success	Last Failure	Last Duration	LC
		core_selenium-test	N/A	2 yr 0 mo - #18	12 min	
		infra_backend-merge-all-repo	1 mo 8 days - #138	3 days 13 hr - #143	5 hr 8 min	
		infra_backend-war-size-tracker	1 mo 9 days - #731	12 hr - #770	1 min 11 sec	
		infra_commit_history_generation	4 mo 22 days - #421	22 hr - #562	4 min 8 sec	
		infra_extension-indexer	1 mo 10 days - #128	4 days 1 hr - #134	3 hr 23 min	
		infra_github_repository_list	1 mo 9 days - #1339	12 hr - #1378	4 min 39 sec	
		infra_plugin_changes_report	8 mo 0 days - #304	2 days 8 hr - #340	13 min	
		infra_plugins_svn_to_git	4 yr 0 mo - #593	3 yr 12 mo - #768	4 min 54 sec	
		infra_svnsync	3 yr 9 mo - #21199	3 yr 9 mo - #21243	1.5 sec	
		infra_sync_maven-hpi-plugin_www	N/A	2 hr 39 min - #376	2.7 sec	
		jenkins_pom	1 mo 14 days - #264	2 days 20 hr - #270	47 sec	
		jenkins_ui-changes_branch	2 yr 5 mo - #32	2 yr 1 mo - #33	4 min 55 sec	
		lib-jira-api	9 mo 25 days - #5354	6 mo 21 days - #5355	58 sec	
		libs_svnkit	N/A	2 yr 9 mo - #11	19 sec	
		selenium-tests	N/A	2 yr 0 mo - #11	22 sec	

Icon: [S](#) [M](#) [L](#)

[Legend](#) [RSS for all](#) [RSS for failures](#) [RSS for just latest builds](#)



Software destacado On-prem / Cloud

Orquestación y despliegue (CD)



kubernetes

The screenshot displays the Spinnaker web interface for managing deployments. The main view shows the 'Pipelines' section for the 'mdservice' application. The pipeline consists of several stages: 'MY-KUBERNETES-ACCOUNT' (Deploy to Stage), 'Validate', 'MY-KUBERNETES-ACCOUNT' (Promote to Prod), and 'VALIDATE PIPELINE'. The 'Deploy to Stage' stage is currently selected, showing a progress bar and a 'Status: SUCCEEDED' message. Below the pipeline list, a 'STAGE DETAILS: DEPLOY PROD (RED/BLACK)' section provides a detailed view of the deployment process, including a table of steps and their status.

Step	Started	Duration	Status
Deploy in default	2017-05-16 14:24:17 PDT	01:02	SUCCEEDED
Disable Cluster	2017-05-16 14:25:20 PDT	02:01	SUCCEEDED

The 'DEPLOY IN DEFAULT' section shows the deployment configuration for the 'mdservice' application, including the account, region, cluster, and strategy. The deployment is identified as 'mdservice-prod-v059'.

DevOps en Cloud



Google Cloud



Microsoft Azure



amazon
web services



RED HAT®
OPENSIFT
Container Platform

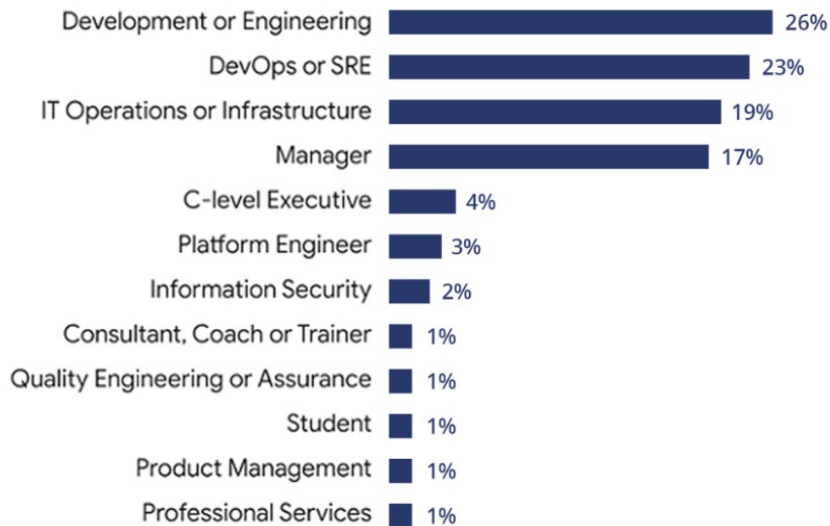
También on-prem (OKD) – <https://okd.io>

DevOps

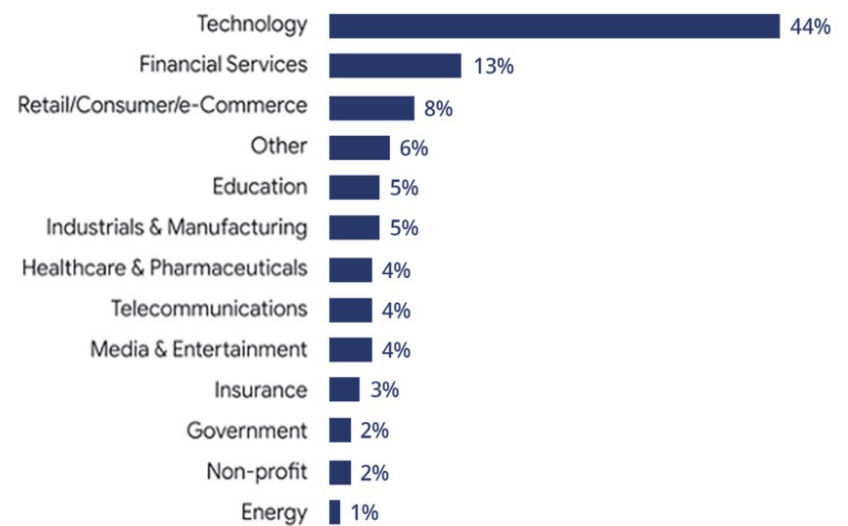
	2022	% change over 2021
Hybrid cloud	42.47%	25%
Public and/or Multiple public	76.08%	36%
Private Cloud	32.55%	12%
No Cloud	10.55%	-50%

Source – Google Cloud – State of DevOps 2022

<https://cloud.google.com/devops/state-of-devops?hl=es>



Source – Google Cloud – State of DevOps 2022



Source – Google Cloud – State of DevOps 2022

DEVOPS

Sesión 1

IMPLEMENTANDO CI/CD CON GITHUB ACTIONS

Github Actions



- Herramienta de GitHub que permite crear flujos de trabajo personalizados para integrar, compilar, probar, verificar, desplegar, etc. código.
- Integración con infinidad de herramientas DevOps como las que hemos revisado, scripting, etc.
- Marketplace de Actions con acciones predefinidas para la mayor parte de tareas habituales.
- **Gratuito** para la mayoría de las necesidades habituales.
- En constante crecimiento y con cada vez mayor soporte por parte de la comunidad.
- Posibilidad de utilizarlo para orquestar todo el flujo CI / CD de casi cualquier tipo de proyecto, incluso On-Premise (de pago).

Github Actions



- **Workflow:** Define el flujo de trabajo que realizará el Action. Se especifica mediante un archivo YAML (Yet Another Markup Language) o, también, YAML Ain't Markup Language.
- **Job:** Conjunto de pasos a realizar dentro de un flujo de trabajo.
- **Step:** Cada uno de los pasos dentro de un Job.
- **Runner:** Máquinas virtuales donde se ejecutan los Jobs. Pueden ser propias de GitHub (hosted) o propias (self-hosted).
- **Events: Triggers** que provocan la ejecución del workflow. Pueden ser **push** al repositorio, creación de una **pull request**, **merge**, o incluso sentencias **CRON** para trabajos temporizados.

Github Actions



La configuración de las Github Actions se hace sobre archivos `.yml` en el directorio `.github/workflows` del repositorio.

Ejemplo de Github Action:

```
1  name: Mi primer action!
2
3  on:
4    pull_request:
5      branches: [ "develop" ]
6    workflow_dispatch:
7
8  |
9  jobs:
10
11    nombre-del-job:
12
13      # Tipo de runner en el que se ejecutará el job
14      runs-on: ubuntu-latest
15
16      # Secuencia de tareas
17      steps:
18        # Descarga del repositorio a la ruta $GITHUB_WORKSPACE
19        - uses: actions/checkout@v4
20
21        # Ejecuta un comando en el shell
22        - name: Step Hola mundo
23          | run: echo Hello, world!
24
25        # Otro comando
26        - name: Step varios comandos
27          | run: |
28            | echo Y aquí otra ejecución! Listado de archivos descargados del repositorio
29            | ls -al $GITHUB_WORKSPACE
```

Github Actions



Standard GitHub-hosted runners for public repositories [↗](#)

For public repositories, jobs using the workflow labels shown in the table below will run on virtual machines with the associated specifications. The use of these runners on public repositories is free and unlimited.

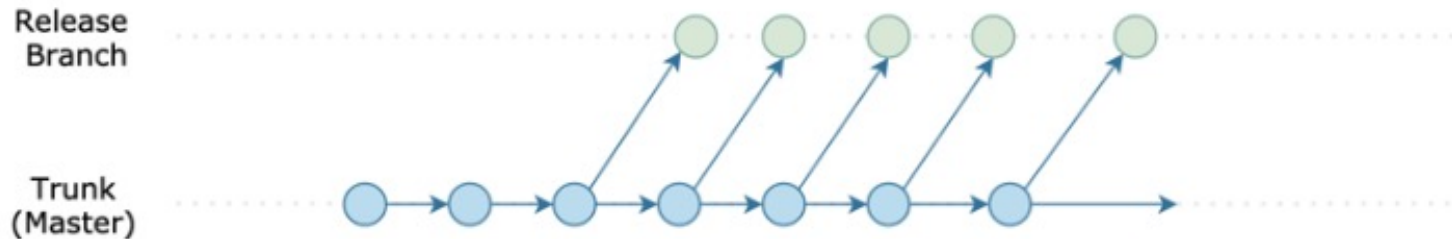
Virtual Machine	Processor (CPU)	Memory (RAM)	Storage (SSD)	Workflow label
Linux	4	16 GB	14 GB	ubuntu-latest , ubuntu-24.04 , ubuntu-22.04 , ubuntu-20.04
Windows	4	16 GB	14 GB	windows-latest , windows-2022 , windows-2019
macOS	3	14 GB	14 GB	macos-12
macOS	4	14 GB	14 GB	macos-13
macOS	3 (M1)	7 GB	14 GB	macos-latest , macos-14 , macos-15 [Public preview]

GitFlow



Repaso flujo de trabajo Github (trunk based vs github flow)

Trunk Based Development

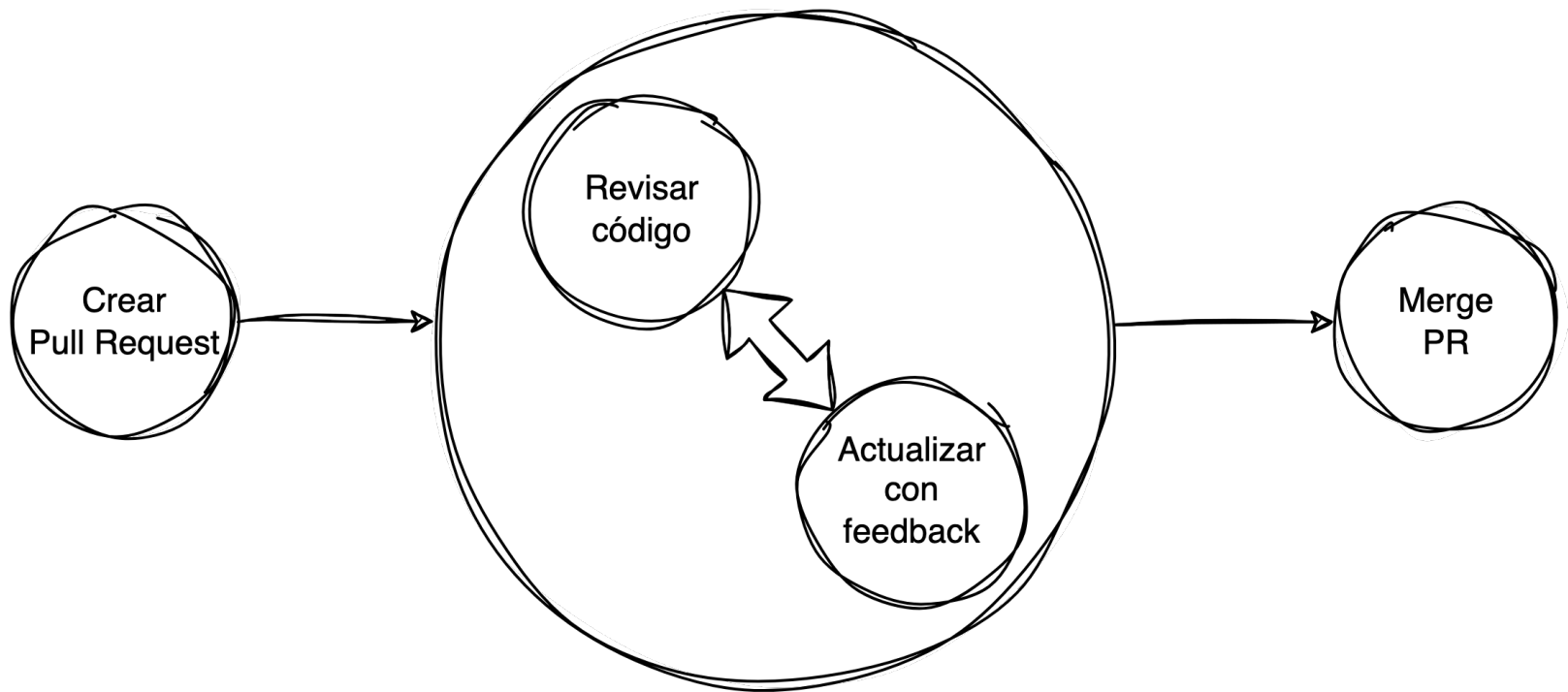


fuelle: dev.to

Github Flow	Trunk based flow
Independencia de miembros del equipo para trabajar en funcionalidades diferentes.	Problemas con long lived branches.
Facilidad para realizar release sin detener el flujo de trabajo.	Commits frecuentes para que funcione.
Adecuado con equipos grandes y/o gran cantidad de desarrolladores junior.	El primer que sube “gana”. Esto también ocurre con git flow, pero menos problemático (menos conflictos en los merges).

Pull Requests

Una Pull Requests no es un merge, es una solicitud para realizar un merge de una rama sobre otra. ¿Porqué se llama **pull** y no **push**?

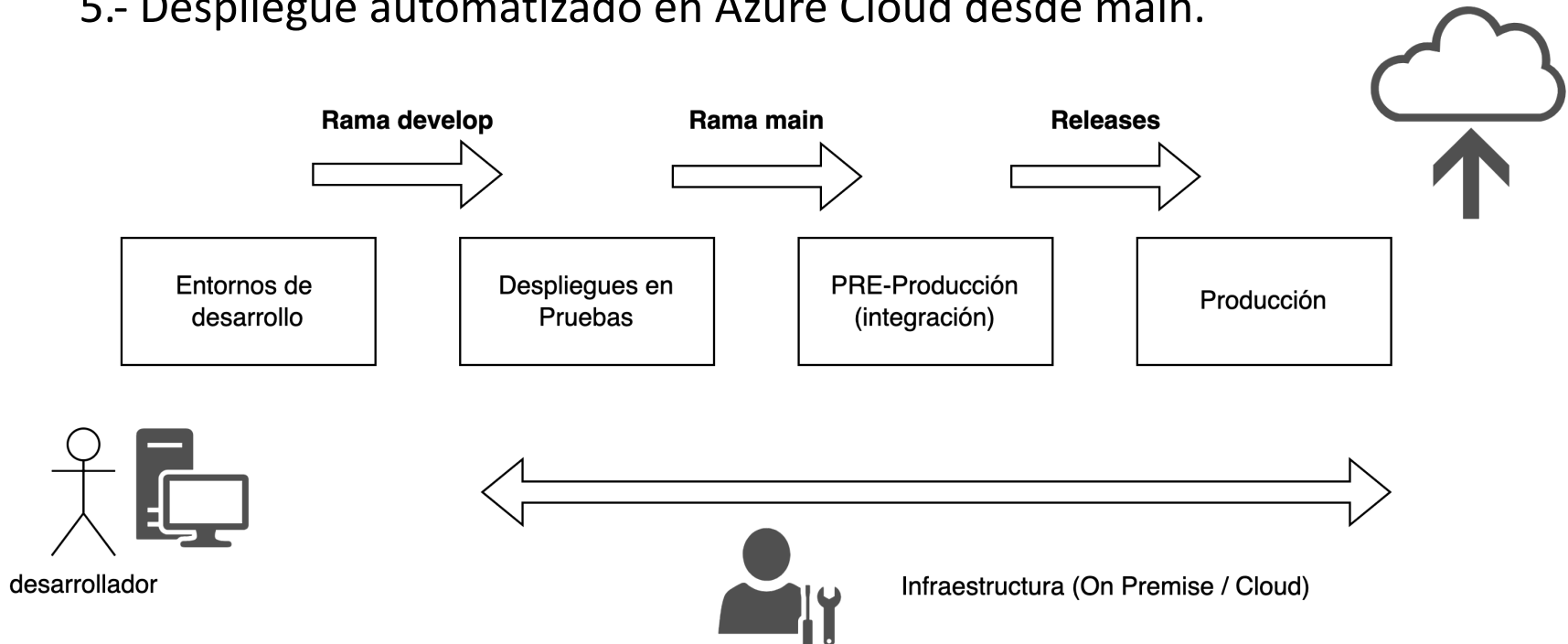


Github Actions



A lo largo de las siguientes sesiones, implementaréis el siguiente flujo CI/CD:

- 1.- Rama develop para subidas frecuentes de desarrolladores.
- 2.- Rama main estable + Workflow Hola Mundo!
- 3.- Check fugas de secretos en todos los pull-request usando Python3.
- 4.- Verificaciones de seguridad con Snyk.io
- 5.- Despliegue automatizado en Azure Cloud desde main.



Github Actions



Descargar (zip) el repositorio generado para estas sesiones:

https://github.com/msectest/demos_cicd

Sesión 1

En esta sesión aprenderemos:

- Github Actions: Qué son, para qué sirven y cómo configuralas.
- Creación y configuración de ramas.
- Gestión de Pull requests.
- Introducción a Rulesets (Requerir pull-requests para merges sobre develop y main)

Tarea 1:

Crea un repositorio con tu cuenta Github que contenga el contenido de este, que puedes descargar como .zip desde la interfaz.

En ese repositorio, realiza la siguiente configuración:

- Configura el repositorio para que no se pueda subir contenido directamente a develop y/o main.
- Crea una nueva rama develop y súbela al repositorio.
- Copia el contenido descargado previamente a dicha rama develop.

Github Actions



Comandos básicos con ramas:

- **git branch:** Mostrar todas las ramas.
- **git checkout nombre_rama:** Cambiar a una rama local existente.
- **git checkout -b nueva_rama:** Crear una nueva rama local a partir del punto actual.

Ejemplo:

```
ruben@ubuntu:~/msec/repo_git/actions$ git branch
* develop
  main
ruben@ubuntu:~/msec/repo_git/actions$ git checkout -b feature/add_hello_action
Switched to a new branch 'feature/add_hello_action'
ruben@ubuntu:~/msec/repo_git/actions$
```

☒ **Require a pull request before merging**

Require all commits be made to a non-target branch and submitted via a pull request before they can be merged.

Hide additional settings ^

Required approvals

0 ▾

Github Actions



Tarea 2 disponible en el repositorio:

Crea un flujo de trabajo nuevo "Hola Mundo" que saque este mensaje en consola y muestre el contenido del repositorio con un pequeño script Bash.

- Estando en la rama develop, crea una nueva rama, por ejemplo feature/nuevo-flujo-holamundo
- Crea y edita el flujo en el directorio `.github/workflows` empleando la ayuda disponible en Github.
- Sube el contenido de la nueva rama y activa el flujo creando una pull request de la rama sobre develop.
- Verifica el funcionamiento del flujo.
- Fin!

Get started with GitHub Actions

Build, test, and deploy your code. Make code reviews, branch management, and issue triage

Skip this and [set up a workflow yourself](#) →

Suggested for this repository

Simple workflow

By GitHub

Start with a file with the minimum necessary structure.

Configure

Github Actions



Creación de la PR:

 **actions** Public

 Pin  Unwatch 1

 **feature/add_hello_action** had recent pushes 16 seconds ago Compare & pull request

 develop  3 Branches  Tags t Add file <> Code

 Rubén Subida inicial e3de58c · 46 minutes ago 🕒 2 Commits
 app Subida inicial 46 minutes ago
 .gitignore Subida inicial 46 minutes ago
 INSTALL.txt Subida inicial 46 minutes ago
 LICENSE Initial commit yesterday
 README.md Subida inicial 46 minutes ago

Github Actions



El flujo se ejecuta:

← Mi primer action!

✓ Subimos el action hola mundo #1

Summary

Jobs

✓ nombre-del-job

Run details

Usage

Workflow file

nombre-del-job

succeeded now in 3s

- > ✓ Set up job
- > ✓ Run actions/checkout@v4
- > ✓ Step Hola mundo

✓ Step varios comandos

```
1 ► Run echo Y aquí otra ejecución! Listado de archivos descargados del repositorio
5 Y aquí otra ejecución! Listado de archivos descargados del repositorio
6 total 68
7 drwxr-xr-x 5 runner docker 4096 Oct 25 22:51 .
8 drwxr-xr-x 3 runner docker 4096 Oct 25 22:51 ..
9 drwxr-xr-x 8 runner docker 4096 Oct 25 22:51 .git
10 drwxr-xr-x 3 runner docker 4096 Oct 25 22:51 .github
11 -rw-r--r-- 1 runner docker 27 Oct 25 22:51 .gitignore
12 -rw-r--r-- 1 runner docker 944 Oct 25 22:51 INSTALL.txt
13 -rw-r--r-- 1 runner docker 35149 Oct 25 22:51 LICENSE
14 -rw-r--r-- 1 runner docker 1592 Oct 25 22:51 README.md
15 drwxr-xr-x 4 runner docker 4096 Oct 25 22:51 app
```

- > ✓ Post Run actions/checkout@v4
- > ✓ Complete job

DEVOPS

Sesión 2

IMPLEMENTANDO CI/CD CON GITHUB ACTIONS

https://github.com/msectest/demos_cicd

Github Actions



Sesión 2

En esta sesión continuaremos creando un flujo de trabajo adicional, poniendo en práctica los conocimientos de python adquiridos.

Aprenderemos:

- Integrar un script python en un Github Action.
- Técnicas de análisis estático de código, verificación de fuga de secretos, etc.
- Mecanismos de protección de ramas (Bloquear merges de PRs en base a resultados).

Tarea 1:

Crear una rama nueva (por ejemplo, feature/check-secrets) que permita detectar posibles fugas de secretos.

Esta rama debe contener:

- Script en python (a desarrollar) que analice un directorio en busca de una palabra clave.
- Flujo de trabajo que utilice el script anterior para buscar, en el repositorio de código, cualquier archivo que pueda contener la palabra reservada **password**
- El script deberá terminar con error en caso de que se encuentre algún secreto.

Marketplace Github Actions: <https://github.com/marketplace/actions>

Tip! Códigos de salida: <https://docs.github.com/en/actions/sharing-automations/creating-actions/setting-exit-codes-for-actions>

Github Actions



Tips:

- Utilizad el asistente para buscar como ejecutar un script externo en Python.
- El script deberá estar disponible en el repositorio, quizás en un subdirectorio dentro de los flujos.
- Recordad que el código está descargado en: **`$GITHUB_WORKSPACE`**

Resultado esperado:

```

  1 ▶ Run python $GITHUB_WORKSPACE/.github/workflows/scripts/secret_finder.py $GITHUB_WORKSPACE/app/src password
 11 Encontrado en App.test.js, línea 4:
 12 Error: Process completed with exit code 1.
```

El script analiza el código y arroja un error como resultado, si se han configurado los códigos de salida correctamente. **¿Nos permite ejecutar la Pull Request?**
¿Cómo lo podríamos solventar?

Github Actions



Al igual que en la sesión anterior, podemos utilizar Rulesets para forzar que no se pueda ejecutar una PR en caso de que no se pasen determinados checks, protegiendo el código y la infraestructura.

Ejemplo de configuración:

☒ **Require status checks to pass**
Choose which status checks must pass before the ref is updated. When enabled, commits must first be pushed to another ref where the checks pass.

Hide additional settings ^

☐ **Require branches to be up to date before merging**
Whether pull requests targeting a matching branch must be tested with the latest code. This setting will not take effect unless at least one status check is enabled.

☐ **Do not require status checks on creation**
Allow repositories and branches to be created if a check would otherwise prohibit it.

Status checks that are required

+ Add checks ▾

check-secrets

 GitHub Actions 

Github Actions



Tarea 2:

¿Se han detectado passwords? Si es así, ¿Nos ha dejado realizar el merge igualmente?. Para evitarlo, debemos configurar Github para que no permita ejecutar las PR.

Una vez configurado, ¿Permite mezclar la PR? Eliminar el password, subir a la rama con commit + push y volver a probar.



**All checks have failed**[Hide all checks](#)

1 failing check

 **Verificar secretos con python / check-secrets (pull_request)** Failing after 4s Required [Details](#)

**Required statuses must pass before merging** [View rules](#)

All required [statuses](#) and check runs on this pull request must run successfully to enable automatic merging.

Merge pull request

You can also [open this in GitHub Desktop](#) or view [command line instructions](#).



**All checks have passed**[Show all checks](#)

1 successful check

**This branch has no conflicts with the base branch**

Merging can be performed automatically.

Merge pull request

You can also [open this in GitHub Desktop](#) or view [command line instructions](#).

DEVOPS

Sesión 3

IMPLEMENTANDO CI/CD CON GITHUB ACTIONS

https://github.com/msectest/demos_cicd

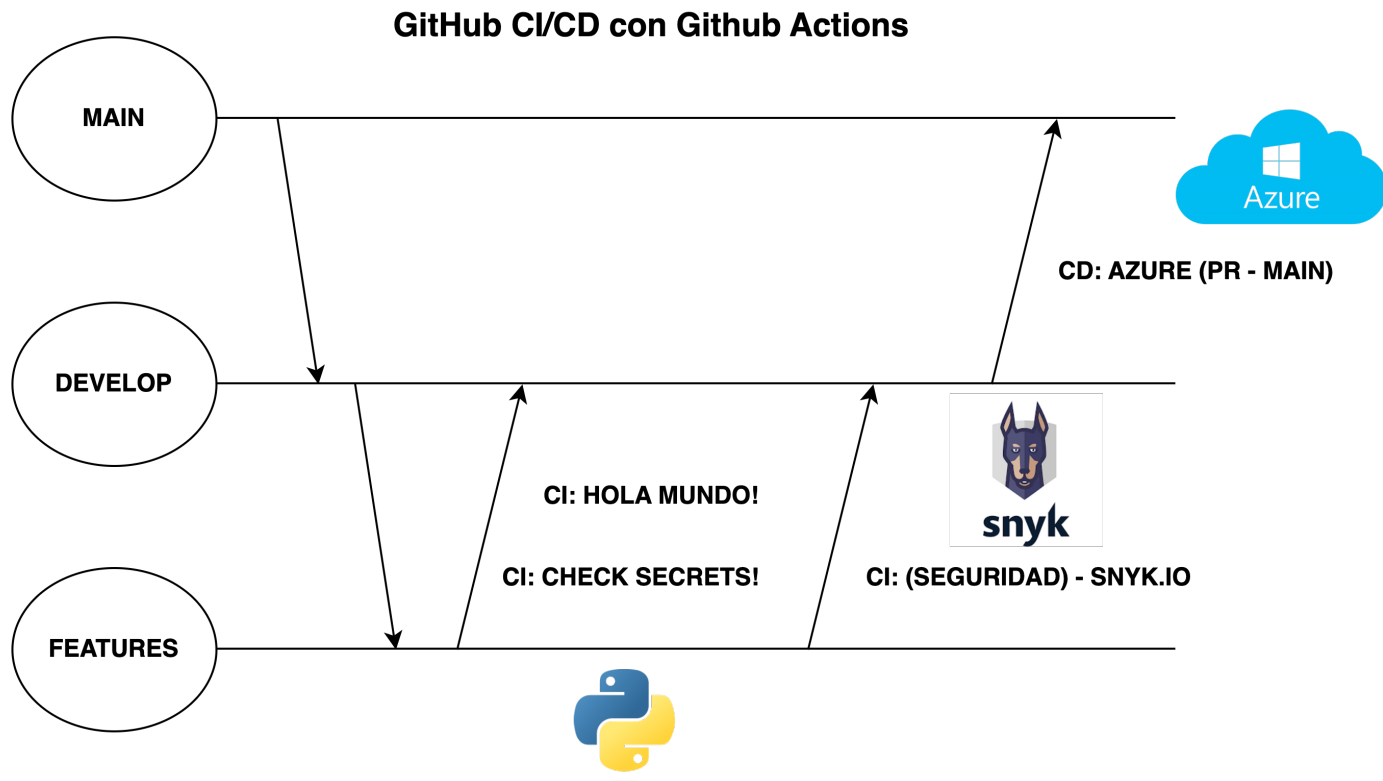
Github Actions



Hasta ahora, hemos visto DevOps. Vamos a añadir “Sec” utilizando un middleware de terceros, **Snyk.io** -> **DevSecOps**.

Herramienta SAST (Static Application Security Testing) y DAST (Dynamic App....).

SAST: Análisis de código vs **DAST**: Análisis del “runtime” (pruebas caja negra). Hay otras (SonarQube, enfocado a SAST, Jit.io...)



Github Actions



En esta sesión añadiremos verificaciones de seguridad adicionales a las ya implementadas apoyándonos en Snyk.io (<https://snyk.io>). Gratuito para desarrollo individual. Se puede utilizar la misma cuenta Github.

Sesión 3

El objetivo de esta sesión es ver como, de modo sencillo, podemos implementar DevSecOps sin más que integrar y configurar una herramienta de detección de vulnerabilidades con Github Actions.

Aprenderemos:

- Conexión con herramientas externas desde Github Actions.
- Uso de secretos en Github Actions.
- Bloqueo de modificaciones inseguras.
- Informes de Seguridad en formato SARIF (Static Analysis Results Interchange Format).
- Modelado de seguridad en función de criticidad.

Github Actions



Desde el directorio de la aplicación (tras INSTALL.txt), ejecutar **snym test**:

```
ruben@ubuntu:~/msec/repo_git/demos_cicd/app$ snyk test

Testing /home/ruben/msec/repo_git/demos_cicd/app...

Tested 1269 dependencies for known issues, found 7 issues, 7 vulnerable paths.

Issues to fix by upgrading:

  Upgrade jquery@3.4.0 to jquery@3.5.0 to fix
  X Cross-site Scripting (XSS) [Medium Severity][https://security.snyk.io/vuln/SNYK-JS-JQUERY-565129] in jquery@3.4.0
    introduced by jquery@3.4.0
  X Cross-site Scripting (XSS) [Medium Severity][https://security.snyk.io/vuln/SNYK-JS-JQUERY-567880] in jquery@3.4.0
    introduced by jquery@3.4.0

Issues with no direct upgrade or patch:
  X Missing Release of Resource after Effective Lifetime [Medium Severity][https://security.snyk.io/vuln/SNYK-JS-INFLIGHT-6095116] in inflight@1.0.6
    introduced by react-scripts@5.0.1 > babel-jest@27.5.1 > @jest/transform@27.5.1 > babel-plugin-istanbul@6.1.1 > test-exclude@6.0.0 > glob@7.2.3 > inflight@1.0.6
    No upgrade or patch available
  X Regular Expression Denial of Service (ReDoS) [High Severity][https://security.snyk.io/vuln/SNYK-JS-NTHCHECK-1586032] in nth-check@1.0.2
    introduced by react-scripts@5.0.1 > @svgr/webpack@5.5.0 > @svgr/plugin-svgo@5.5.0 > svgo@1.3.2 > css-select@2.1.0 > nth-check@1.0.2
    This issue was fixed in versions: 2.0.1
```

Github Actions



Crear workflow para implementar las verificaciones de seguridad. Varias alternativas, ya sea con el action predefinido, o replicando los pasos ejecutados en local.

NUEVO!: Configuración del token como secreto en Github.

Tarea 1:

Crear una nueva rama desde develop (por ejemplo, feature/security-check) para añadir nuevo workflow para conectar con Snyk. Sobre esta rama, probamos en local el cliente Snyk (si no se ha instalado, instalar con instrucciones INSTALL.txt)

- Ejecutar, en el directorio base (package.json), el comando: `snyk test`
- Revisar resultados. Existen vulnerabilidades, por lo que configuraremos Github para que no permita consolidar este código fuente.
- Crear el workflow apoyándonos en las actions preconfiguradas.
- Para ello, será imprescindible añadir un secreto con el TOKEN que se haya obtenido de: <https://app.snyk.io/account>
- Revisar resultado del flujo y comprobar que se reportan las vulnerabilidades.

Github Actions



Snyk Node Action

A [GitHub Action](#) for using [Snyk](#) to check for vulnerabilities in your Node projects. This Action is based on the [Snyk CLI](#) and you can use [all of its options and capabilities](#) with the `args`.

You can use the Action as follows:

```
name: Example workflow for Node using Snyk
on: push
jobs:
  security:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@master
      - name: Run Snyk to check for vulnerabilities
        uses: snyk/actions/node@master
        env:
          SNYK_TOKEN: ${ secrets.SNYK_TOKEN }
```



Security

Code security

Deploy keys

Secrets and variables



Actions

Codespaces

Repository secrets

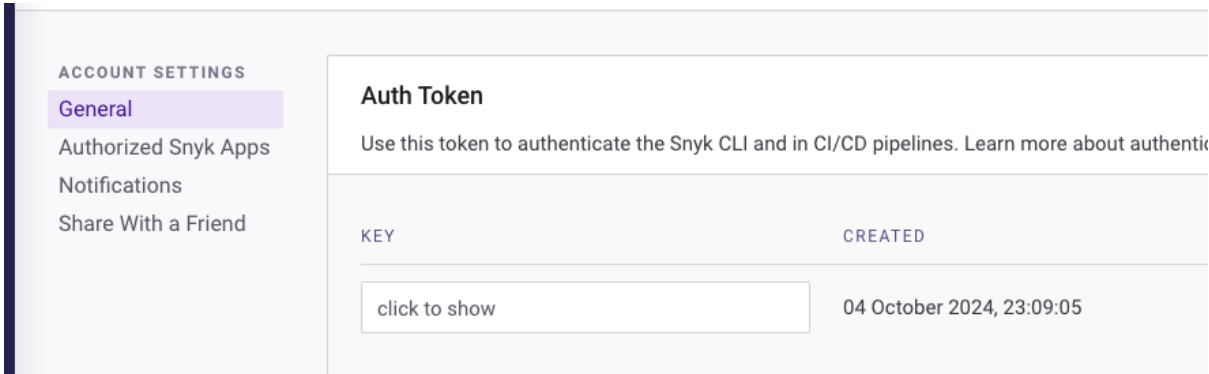
This repository has no secrets.

New repository secret

Github Actions



Recuperar el TOKEN desde: <https://app.snyk.io/account>



Resultado esperado:

```

9
10 Ejecuta snyk para detectar vulnerabilidades
11
12 "GITHUB_WORKFLOW_SHA" -e "GITHUB_WORKSPACE" -e "GITHUB_ACTION" -e "GITHUB_EVENT_PATH" -e "GITHUB_ACTION_REPOSITORY" -e "GITHUB_ACTION_REF" -
13 e "GITHUB_PATH" -e "GITHUB_ENV" -e "GITHUB_STEP_SUMMARY" -e "GITHUB_STATE" -e "GITHUB_OUTPUT" -e "RUNNER_OS" -e "RUNNER_ARCH" -e
14 "RUNNER_NAME" -e "RUNNER_ENVIRONMENT" -e "RUNNER_TOOL_CACHE" -e "RUNNER_TEMP" -e "RUNNER_WORKSPACE" -e "ACTIONS_RUNTIME_URL" -e
15 "ACTIONS_RUNTIME_TOKEN" -e "ACTIONS_CACHE_URL" -e "ACTIONS_RESULTS_URL" -e GITHUB_ACTIONS=true -e CI=true -v
16 "/var/run/docker.sock":"/var/run/docker.sock" -v "/home/runner/work/_temp/_github_home":"/github/home" -v
17 "/home/runner/work/_temp/_github_workflow":"/github/workflow" -v "/home/runner/work/_temp/_runner_file_commands":"/github/file_commands" -v
18 "/home/runner/work/actions/actions":"/github/workspace" snyk/snyk:node "snyk" "test" "$GITHUB_WORKSPACE/app --severity-threshold=high --
19 auth-type=token --sarif-file-output=snyk.sarif"
20
21 9
22 10 Testing /github/workspace/app...
23 11
24 12 Tested 1269 dependencies for known issues, found 1 issue, 1 vulnerable path.
25 13
26 14
27 15 Issues with no direct upgrade or patch:
28 16 x Regular Expression Denial of Service (ReDoS) [High Severity] [https://security.snyk.io/vuln/SNYK-JS-NTHCHECK-1586032] in nth-check@1.0.2
29 17   introduced by react-scripts@5.0.1 > @svgr/webpack@5.5.0 > @svgr/plugin-svgo@5.5.0 > svgo@1.3.2 > css-select@2.1.0 > nth-check@1.0.2
30 18   This issue was fixed in versions: 2.0.1
```

Github Actions



Tarea 2:

Añadir nueva verificación para que este flujo pase a formar parte de las verificaciones obligatorias:

- Verificar que no se puede completar la PR tras añadir la nueva verificación.
- Modificar el flujo para que, además, se reporten los resultados en formato SARIF. El resultado estará disponible en la pestaña Security.
- Solucionar los problemas de seguridad siguiendo las indicaciones de Snyk y añadir umbral a High. En caso de no existir estrategias de mitigación, se pueden ignorar dependencias con el comando `snyk ignore`.
- Comprobar que ya se puede ejecutar la PR.
- Por último, integrar desde Snyk para ver otras posibilidades. ¿Qué inconvenientes veis? ¿Preferencias?



**Some checks haven't completed yet**

2 in progress and 1 expected checks

[Hide all checks](#)

 Verificaciones de seguridad con Snyk / security-check (pull_request) *In progress — This check ...*

[Details](#)

 Verificaciones de seguridad con Snyk v2 / security-check-v2 (pull_request) *In progress — This ...*

[Details](#)

 **check-secrets** *Expected — Waiting for status to be reported*

Required

**Required statuses must pass before merging**

[View rules](#)

All required [statuses](#) and check runs on this pull request must run successfully to enable automatic merging.

Merge pull request

▼

You can also [open this in GitHub Desktop](#) or view [command line instructions](#).

Github Actions



Overview

Reporting

Policy

Advisories

Vulnerability alerts

Dependabot

Code scanning

Secret scanning

Code scanning

☐ Configured tools are not scanning the default branch.

+ Add tool

pr:3 is:open

Clear current search query, filters, and sorts

☐ 7 Open ✓ 0 Closed

Tool ▾ Branch ▾ Rule ▾ Severity ▾ Sort ▾

☐ **High severity - Regular Expression Denial of Service (ReDoS) vulnerability in nth-check** **High** refs/pull/3/merge
#1 opened 6 minutes ago • Detected by Snyk Open Source in package.json :1

☐ **Medium severity - Cross-site Scripting (XSS) vulnerability in serialize-javascript** **Medium** refs/pull/3/merge
#7 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

☐ **Medium severity - Cross-site Scripting (XSS) vulnerability in rollup** **Medium** refs/pull/3/merge
#6 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

☐ **Medium severity - Improper Input Validation vulnerability in postcss** **Medium** refs/pull/3/merge
#5 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

☐ **Medium severity - Cross-site Scripting (XSS) vulnerability in jquery** **Medium** refs/pull/3/merge
#4 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

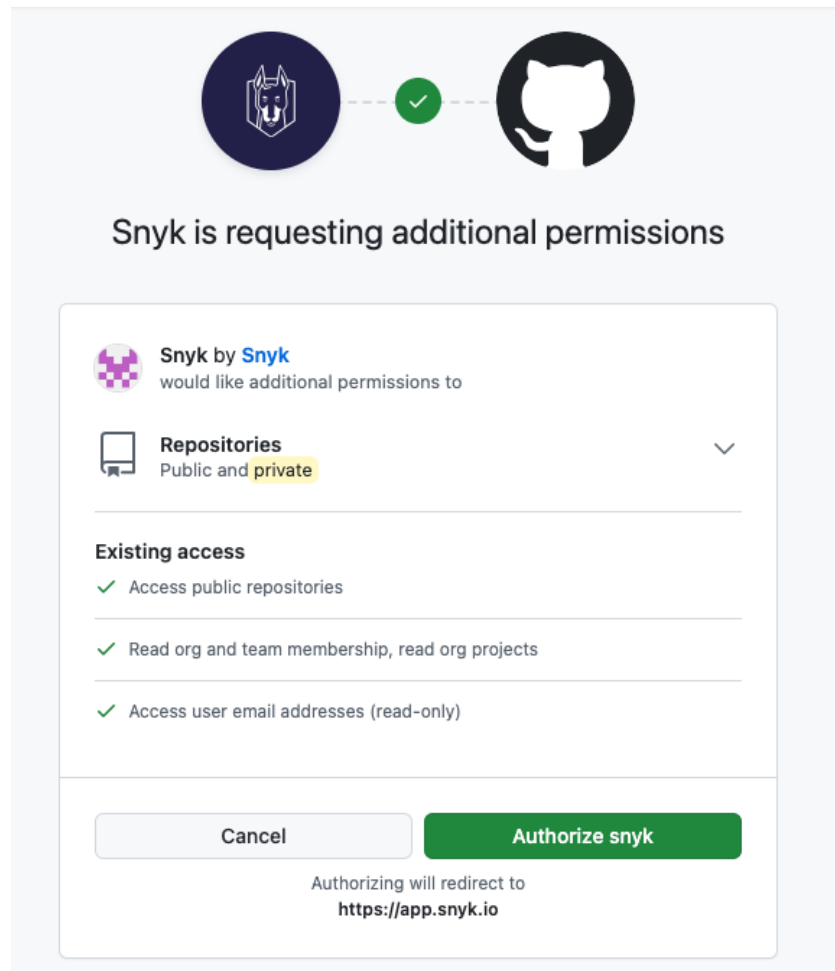
☐ **Medium severity - Cross-site Scripting (XSS) vulnerability in jquery** **Medium** refs/pull/3/merge
#3 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

☐ **Medium severity - Missing Release of Resource after Effective Lifetime vulnerability in inflight** **Medium** refs/pull/3/merge
#2 opened 3 minutes ago • Detected by Snyk Open Source in package.json :1

Github Actions



Por último, también es posible integrar el repositorio desde Snyk, delegando en esta herramienta esta parte de las verificaciones.



Github Actions



Por último, también es posible integrar el repositorio desde Snyk, delegando en esta herramienta esta parte de las verificaciones.

msectest > [Projects](#) > msectest/actions develop Open on GitHub

app/package.json

Overview History Settings

Issues 7 Fixes Dependencies 1268

Search...

Fix these vulnerabilities

7 of 7 issues Sort by highest priority score

SEVERITY

☐ Critical	0
☐ High	1
☐ Medium	6
☐ Low	0

PRIORITY SCORE
Scored between 0 - 1000

"FIXED IN" AVAILABLE

☐ Yes	6
☐ No	1

COMPUTED FIXABILITY

☐ Fixable	2
☐ Partially fixable	0
☐ No supported fix	5

jquery - Cross-site Scripting (XSS) SCORE 711

VULNERABILITY | [CWE-79](#) | [CVE-2020-11022](#) | [CVSS 6.5](#) MEDIUM | [SNYK-JS-JQUERY-567880](#)

Insights: This vulnerability is only applicable on applications that allow users to write any HTML or dynamically append HTML (even sanitized) with jQuery.

Introduced through jquery@3.4.0 Exploit maturity MATURE

Fixed in jquery@3.5.0

Show more detail

[Learn about this type of vulnerability](#)

Ignore Fix this vulnerability

DEVOPS

Sesión 4

IMPLEMENTANDO CI/CD CON GITHUB ACTIONS

https://github.com/msectest/demos_cicd

Github Actions



Para finalizar, vamos a desplegar el artefacto generado en Azure. Quien desee probar, puede utilizar el plan de estudiante <https://azure.microsoft.com/es-es/free/students>

Tarea 1:

Aprovisionar en Azure un nuevo App Service, que será donde despleguemos la aplicación.

- Seleccionar el plan gratuito, suficiente para este ejemplo.
- Habilitar la autenticación básica para poder descargar el perfil de publicación.
- Una vez aprovisionado el App Service, descargar el perfil de publicación y guardarlo para la siguiente tarea.
- Como resultado, tendremos un dominio con una página por defecto de Microsoft publicada.
- **IMPORTANTE:** En la configuración de Azure, una vez creado el App Service, añadir como comando de inicio:

```
pm2 serve /home/site/wwwroot --no-daemon --spa
```

Crear soluciones en la nube gratis con Azure for Students

Usa el correo electrónico de tu universidad o centro educativo para registrarte y renovar cada año que seas estudiante.

[Empezar gratis](#)[Más información acerca de los requisitos](#)

Comenzar
con un
crédito de
Azure de
100 USD

No se
requiere
tarjeta de
crédito

Github Actions



Al finalizar, el dominio publicado se verá como en la siguiente figura.



La aplicación web se está ejecutando y está esperando el contenido

Su aplicación web está activa, pero aún no tenemos su contenido. Si ya ha implementado, el contenido puede tardar hasta 5 minutos en mostrarse, así que vuelva pronto.



Compatibilidad con Node.js, Java, .NET y mucho más

¿Aún no ha implementado?
Use el centro de implementación para publicar código o configurar la implementación continua.

[Centro de implementación](#)

¿Está empezando un nuevo sitio web?
Siga nuestra guía de inicio rápido para preparar una aplicación web rápidamente.

[Inicio rápido](#)

IMPORTANTE: Descargar el perfil de publicación desde la página principal de administración y configurar el script de inicio según instrucciones en el workflow.

Github Actions



Para terminar, añadir en una nueva rama el flujo para desplegar cuando se realice **push** sobre las rama **main**.

Deployment

Deploy Node.js to Azure Web App

By Microsoft Azure

Build a Node.js project and deploy it to an Azure Web App.

Configure

Deployment 

TIPS:

- Crear el secreto que solicita el flujo para realizar la publicación. El contenido será el del archivo previamente descargado (perfil de publicación).
- Revisar rutas del workflow por defecto para verificar que se usa el workspace.
- Si hay dudas, añadir un step para mostrar el contenido de los directorios y ubicar el proceso.
- El contenido a subir a Azure será el del directorio “**build**” tras realizar **npm run build**.

Github Actions



Si todo va bien....

```
> ✓ Set up job 3s

✓ Download artifact from build job 1s

1 ▶ Run actions/download-artifact@v3
7 Starting download for node-app
8 Directory structure has been setup for the artifact
9 Total number of files that will be downloaded: 15
10 Total file count: 15 ---- Processed file #13 (86.6%)
11 Artifact node-app was downloaded to /home/runner/work/actions/actions
12 Artifact download has finished successfully

✓ Deploy to Azure WebApp 23s

1 ▼ Run azure/webapps-deploy@v2
2 with:
3   app-name: demowebgact
4   publish-profile: ***
5   package: .
6   slot-name: production
7 env:
8   AZURE_WEBAPP_NAME: demowebgact
9   AZURE_WEBAPP_PACKAGE_PATH: .
10
11 Package deployment using ZIP Deploy initiated.
12 Deploy logs can be viewed at https://demowebgact-adhehrfqa5c5gtb7.scm.westeurope-01.azurewebsites.net/api/deployments/2327a998-95d9-4bbd-9523-7ffa73ce3b26/log
13 Successfully deployed web package to App Service.
14 App Service Application URL: https://demowebgact-adhehrfqa5c5gtb7.westeurope-01.azurewebsites.net

> ✓ Complete job 1s
```

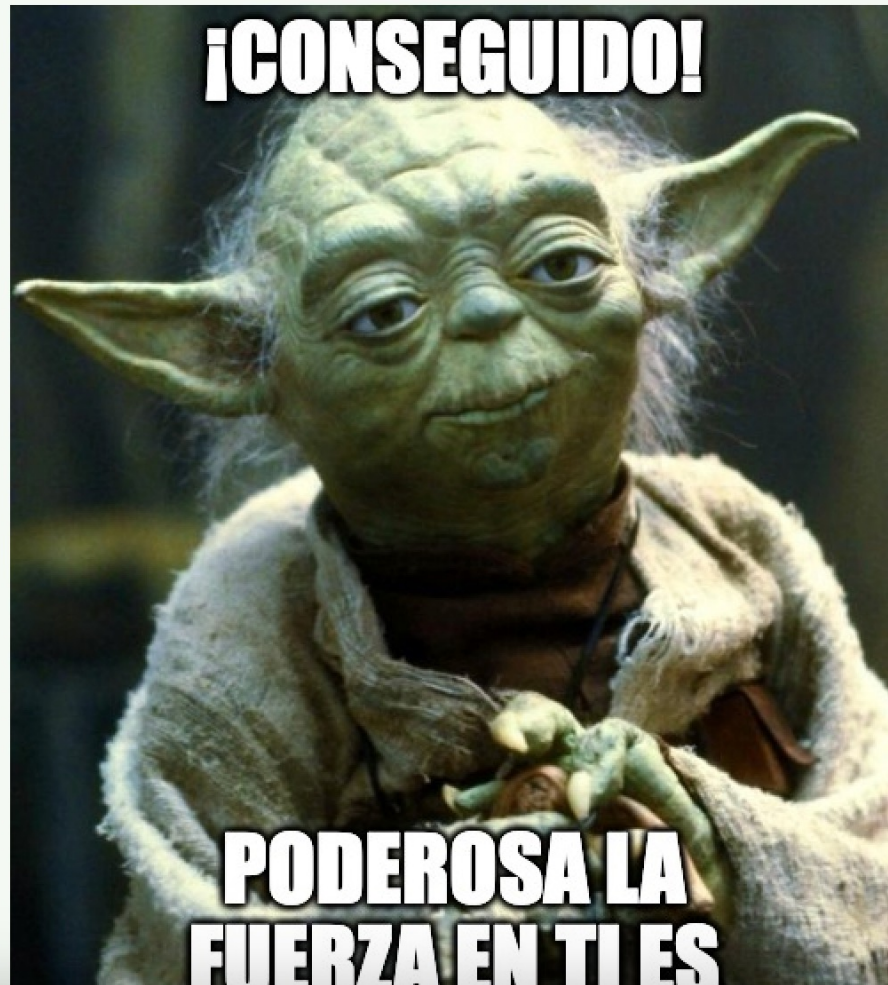
Github Actions



Si todo va bien....

GitHub Actions - Sesión 4

Continuous Delivery con Azure



iii GRACIAS !!!